주차 진행 보고

LLM 기반 DAST 하네스

크롤링 입력 표면 확장 · 인증 세션 처리 · 한계와 과제

입력 표면 확장 › 인증 세션 › 한계·과제

2026-11 · 작성자: 박근령

요약 이번 주 진행 요약

① **입력 표면 확장**
파라미터만 → 경로·쿠키·헤더까지 수집

② **인증 세션 처리**
로그인 시퀀스 — 로그인 후 페이지·쿠키 확보

③ **한계·과제 정리**
봇 차단·세션 바인딩 등 한계와 다음 방향

① 문제 — 파라미터만 수집하던 사각지대

기존 크롤러는 쿼리·폼 파라미터만 수집 → 모든 사용자 입력을 보지 못함

입력 벡터	예 (우리 앱)	기존 탐지
URL 경로	/shop/product/5 의 5	❌ 누락
쿠키	uid · role · track_uid	❌
헤더	User-Agent · X-Forwarded-For	❌
쿼리/폼 파라미터	q · category · username	✅ 유일하게 잡던 것

핵심: name=value 가 아닌 입력(경로 등)은 인식조차 못 함 → 구조적 미탐

① 접근 ⓐ 경로(path) — URL ID 세그먼트

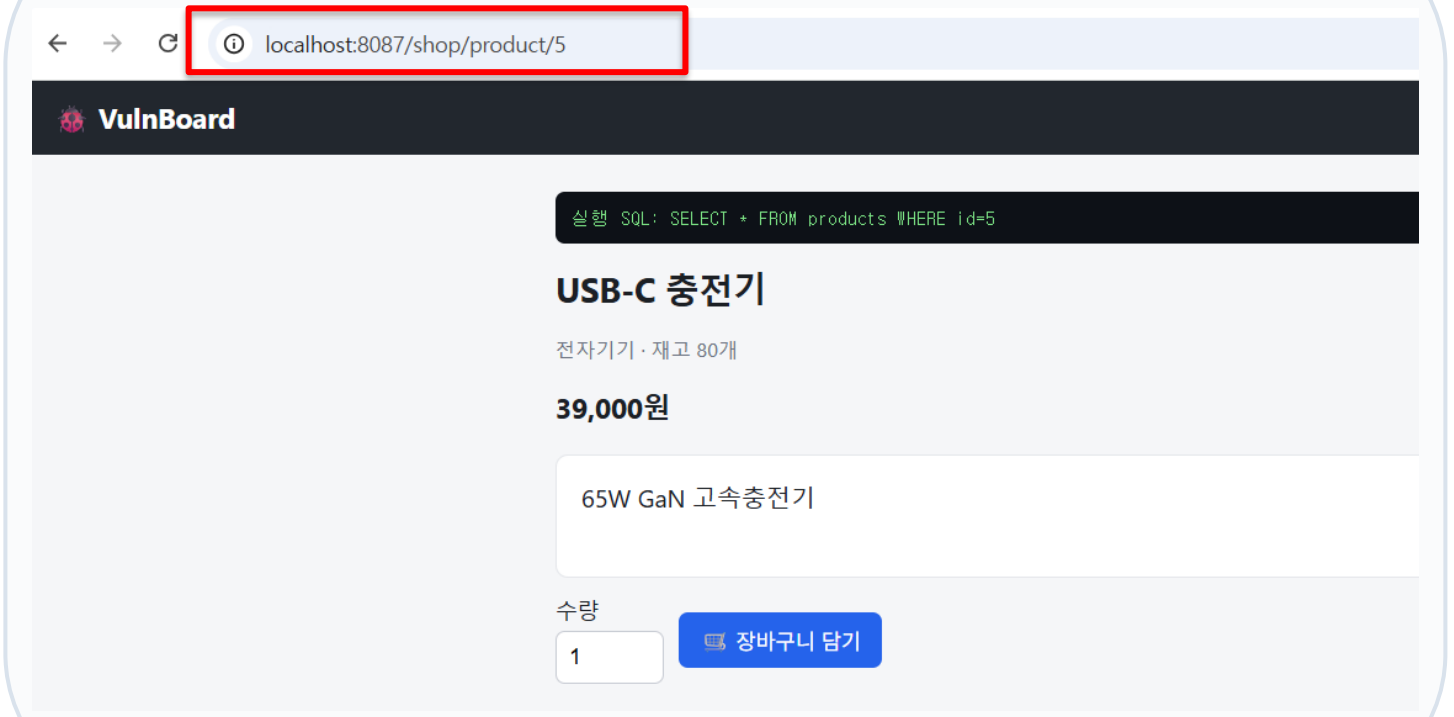
어떻게 수집하나

URL의 ID형 세그먼트 자동 발견

/shop/product/5 → product=5

/{id} 정규화로 중복 1개만

파라미터가 아니어도 주입점 등록



① 접근 ⓑ 쿠키(cookie) — 서버가 발견시켜줌

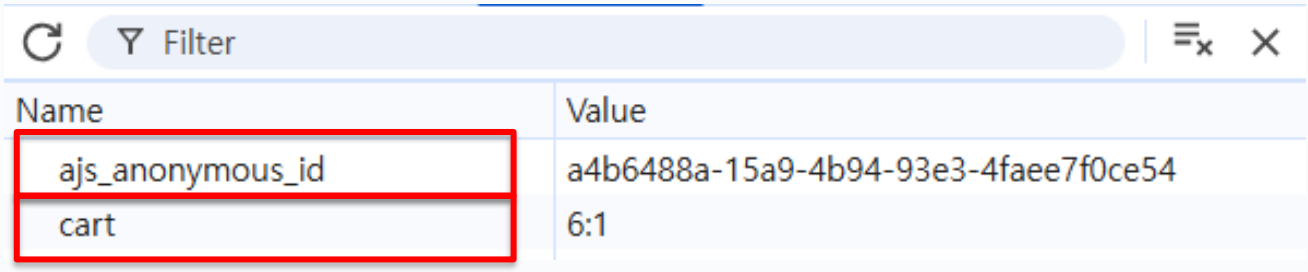
어떻게 수집하나

서버 Set-Cookie 응답을 파싱

→ '발견' (서버가 알려줌)

uid · role · session 등 등록

이름 기준 중복 제거



① 접근 ⓒ 헤더(header) — 고정 목록 주입

어떻게 수집하나

서버가 안 알려줌 → 발견 불가

config 고정 목록(8개) 주입

User-Agent · XFF · Referer 등

커스텀 헤더는 목록에 추가

```
fuzz_headers:
  - User-Agent        # 로그 저장 → SQLi/XSS
  - Referer           # 로그 저장 → SQLi/XSS
  - X-Forwarded-For   # IP 위조 → SQLi/접근제어 우회
  - X-Real-IP
  - Client-IP
  - X-Forwarded-Host  # 호스트 헤더 인젝션/비번재설정 변조
  - X-Forwarded-Proto
  - Host              # 호스트 헤더 인젝션
```

```
Content-Type: application/x-www-form-urlencoded
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) Ap
Safari/537.36 (compatible; Coupang-Withsecurity; +Please
Origin: http://localhost:8087
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,im
d-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer: http://localhost:8087/login
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
```

② 인증 세션 — 로그인 시퀀스

어떻게 처리했나

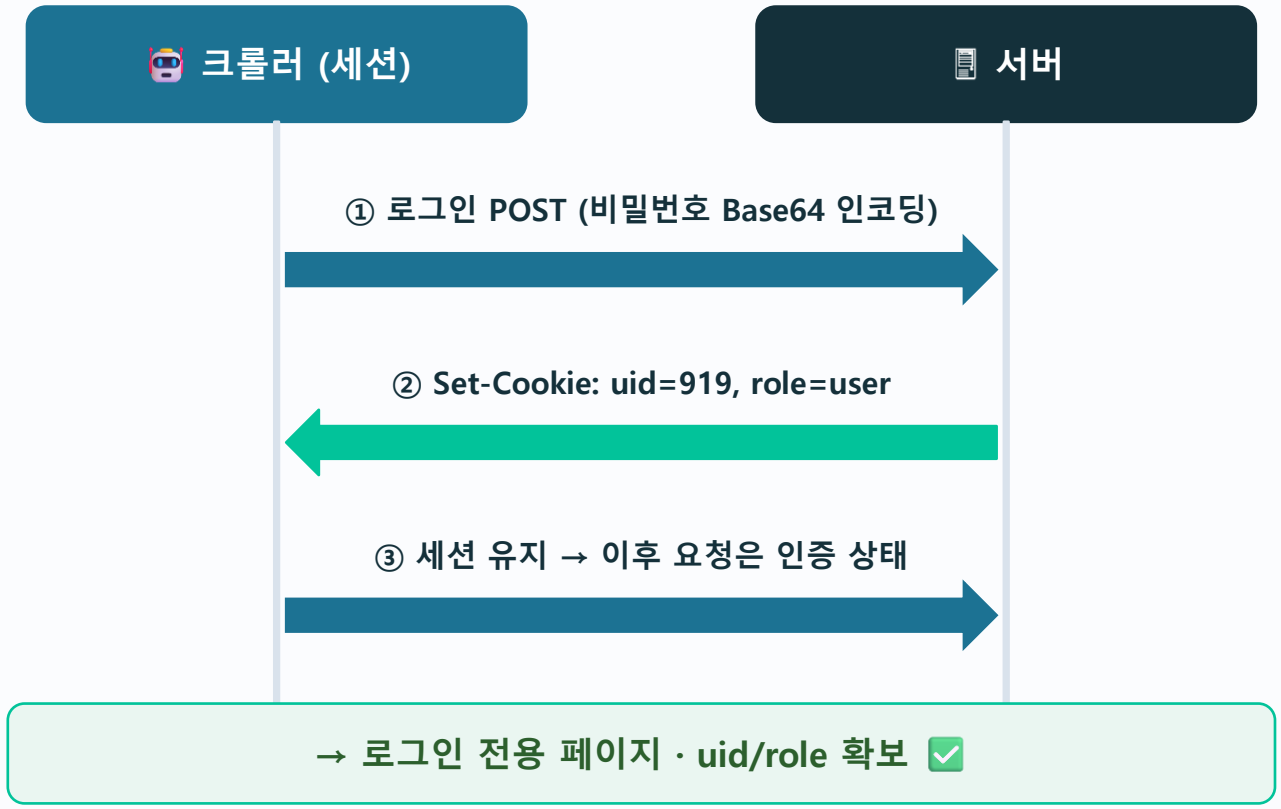
auth.yaml 에 계정 저장

크롤 시작 시 로그인 POST 1회

세션 유지 → 인증 상태로 크롤

비번 base64 인코딩 재현

uid/role 쿠키 자동 캡처



③ 현재 방식의 현실적 한계

한계	내용
CAPTCHA / MFA	사람 증명·2차 인증 → 자동 로그인 불가 (하드)
CSRF / JS 챌린지	1회용 토큰·동적 JS → 현재 미처리
WAF 봇 탐지	매 요청 챌린지 → 비-브라우저 차단
세션 바인딩	IP·UA·TLS 지문에 묶으면 복사 세션 거부
쿠키 아닌 토큰	JWT(헤더)·localStorage → 쿠키 복사 불가

현실적 우회: 사람이 로그인 후 세션 쿠키 + UA/헤더를 넘겨주는 '수동 세션 주입' → IP·UA 바인딩까지 커버 (단 WAF·TLS 지문은 여전히 한계)

③ 해결을 위해 진행할 것 (차주)

자동화 범위 넓히기

- CSRF 토큰 자동 처리 — 로그인 페이지 GET→토큰 추출→POST 포함
- 수동 세션 주입 강화 — 쿠키+UA+Authorization 헤더 묶음 지원

스캔 단계로 연결

- FR-03 스캐너가 path/cookie/header 실제 스캔 (sqlmap * / --cookie / --headers)

검토 과제

- 헤드리스 브라우저(Playwright) — JS ·동적 토큰 대응 (CAPTCHA·WAF는 여전히 난제)